

Security Scan Summary

- Repository: [git@github.com:rkuusisto/lanbooking-api](https://github.com/rkuusisto/lanbooking-api).git
- Branch: main
- Job ID: a3fcdaff-dfa9-44d0-b949-462cb7f68573
- Flagged files: 9

Llama Summary

Security Report for Repository: [git@github.com:rkuusisto/lanbooking-api](https://github.com/rkuusisto/lanbooking-api).git

Summary of Findings:

A total of 9 files in the repository have been flagged with security issues. The distribution of these issues across different files is detailed below:

- 1. docs/frontend-intra.md (1 finding)**
 - Potential vulnerability related to insecure documentation practices.
- 2. keycloak/lanbooking-realm.json (2 findings)**
 - Sensitive information exposure in configuration files.
 - Possible misconfiguration leading to unauthorized access.
- 3. routes/lanbooking.js (1 finding)**
 - Security risk due to potential SQL injection vulnerability.
- 4. utils/executeSql.js (1 finding)**
 - Insecure handling of database queries which could lead to SQL injection or other database-related vulnerabilities.
- 5. keycloak-production/lanbooking-realm.json.template (1 finding)**
 - Sensitive information exposure in template files that may be used for production configuration.
- 6. env.production.example (5 findings)**
 - Multiple security issues including exposure of sensitive environment variables and potential misconfigurations.
- 7. middleware/auth.js (2 findings)**
 - Security risks due to improper authentication mechanisms or insecure session management.
- 8. services/bookingService.js (1 finding)**
 - Potential vulnerability in service layer related to input validation or data handling issues.
- 9. azure-pipelines.yml (1 finding)**

- Security risk due to potential exposure of sensitive information within CI/CD pipeline configuration.

Recommendations:

1. Review and sanitize all flagged files to ensure that no sensitive information is exposed.
2. Implement secure coding practices, particularly in areas related to database queries, authentication mechanisms, and environment variable management.
3. Conduct a thorough security audit to identify additional vulnerabilities that may not have been flagged during this initial scan.
4. Update documentation practices to align with secure development guidelines.
5. Enhance the CI/CD pipeline configuration to prevent exposure of sensitive information in automated build processes.

Action Steps:

1. Assign specific tasks to relevant team members for addressing each issue.
2. Schedule a follow-up meeting within one week to review progress and address any new findings or challenges encountered during remediation.
3. Consider conducting security training sessions for the development team to reinforce best practices and improve overall security posture.

Conclusion:

The repository contains several critical security issues that need immediate attention.

Addressing these findings will significantly enhance the security of the application and protect against potential threats.

Flagged Files

- docs/frontend-intra.md (1 findings)
- keycloak/lanbooking-realm.json (2 findings)
- routes/lanbooking.js (1 findings)
- utils/executeSql.js (1 findings)
- keycloak-production/lanbooking-realm.json.template (1 findings)
- env.production.example (5 findings)
- middleware/auth.js (2 findings)
- services/bookingService.js (1 findings)
- azure-pipelines.yml (1 findings)